ANNEXE C

Politique de Sécurité du Système d'Information (PSSI)

Version : 1.0

Classification : Interne

Statut : Approuvée

Auteur : Consultant Cybersécurité

Approbateur : Direction Générale — Antoine Verger

Historique des versions

Version	Date	Auteur	Description
0.1	15/06/2026	Consultant cybersécurité	Création du document
0.9	20/06/2026	DSI	Relecture technique
1.0	30/06/2026	Direction Générale	Validation officielle

Diffusion

Destinataire	Diffusion
Direction Générale	Oui
DSI	Oui
Responsable RH	Oui
DPO	Oui
Équipe informatique	Oui
Managers	Oui
Collaborateurs	Version adaptée

Confidentialité

Ce document est destiné exclusivement aux personnes autorisées par BioMarket. Il ne peut être diffusé sans l'accord de la Direction.

Table des matières

1. Objet 3

2. Contexte 3

3. Engagement de la Direction 4

4. Champ d'application 4

5. Objectifs du SMSI 5

6. Principes directeurs de la sécurité 5

7. Référentiels applicables 6

8. Définitions 6

9. Organisation de la sécurité de l'information 7

10. Politique de gestion des accès 10

11. Gestion des actifs 12

12. Classification de l'information 13

13. Sécurité des postes de travail 13

14. Sécurité des réseaux 14

15. Politique de sauvegarde et de restauration 15

16. Gestion des incidents de sécurité 16

17. Gestion des changements 17

18. Développement sécurisé 18

19. Sensibilisation et formation 19

20. Conformité, audit et amélioration continue 20

21. Mesures de sécurité prioritaires 21

22. Suivi du SMSI 21

23. Validation de la PSSI 22

Tableau des approbations 22

Conclusion 23

Annexes proposées 24

1. Objet

La présente Politique de Sécurité du Système d'Information (PSSI) définit les principes, les objectifs et les règles de sécurité applicables au système d'information de BioMarket.

Elle constitue le document de référence en matière de gouvernance de la sécurité de l'information. Son objectif est de protéger les actifs informationnels de l'entreprise contre les risques susceptibles de porter atteinte à leur confidentialité, leur intégrité ou leur disponibilité.

Cette politique s'inscrit dans la démarche de mise en œuvre du Système de Management de la Sécurité de l'Information (SMSI) et accompagne le projet de préparation à une certification conforme à la norme **ISO/IEC 27001**.

---

2. Contexte

BioMarket est une entreprise spécialisée dans la distribution de produits biologiques disposant d'un siège social à Tourcoing et d'un réseau de magasins répartis sur le territoire.

Afin d'accompagner son développement, l'entreprise mène un projet de transformation numérique reposant sur la création d'une plateforme de commerce en ligne développée par le prestataire Iron4Software.

Cette évolution accroît l'exposition du système d'information aux cybermenaces et renforce les exigences en matière de protection des données personnelles, de disponibilité des services et de maîtrise des accès.

La mise en place d'une PSSI vise à formaliser les règles de sécurité applicables à l'ensemble de l'organisation afin d'assurer une protection cohérente des informations traitées par BioMarket.

---

3. Engagement de la Direction

La Direction Générale de BioMarket reconnaît que la sécurité de l'information constitue un facteur essentiel de la continuité des activités, de la confiance des clients et de la conformité réglementaire.

À ce titre, elle s'engage à :

- soutenir la mise en œuvre du SMSI ;
- fournir les ressources humaines, techniques et financières nécessaires ;
- promouvoir une culture de la cybersécurité auprès de l'ensemble des collaborateurs ;
- veiller au respect des exigences réglementaires, notamment en matière de protection des données personnelles ;
- intégrer la sécurité de l'information dans les décisions stratégiques de l'entreprise ;
- soutenir une démarche d'amélioration continue conformément aux principes de la norme ISO/IEC 27001.

La Direction confie à la DSI, avec l'appui du consultant cybersécurité durant le projet, la responsabilité du pilotage opérationnel du SMSI et du suivi de la présente politique.

---

4. Champ d'application

La présente PSSI s'applique à l'ensemble des ressources composant le système d'information de BioMarket.

Elle concerne notamment :

- le siège social de Tourcoing ;
- les magasins connectés au système d'information ;
- les collaborateurs, quel que soit leur statut ;
- les prestataires disposant d'un accès au système d'information ;
- les équipements informatiques ;
- les applications métiers ;
- les infrastructures réseau ;
- les services Cloud utilisés par BioMarket ;
- les données professionnelles et les données personnelles.

Les prestataires externes intervenant sur le système d'information devront respecter les exigences définies par cette politique ainsi que les clauses de sécurité prévues dans leurs contrats.

---

5. Objectifs du SMSI

Le SMSI de BioMarket poursuit les objectifs suivants :

- protéger les informations stratégiques de l'entreprise ;
- garantir la confidentialité des données personnelles des clients et des collaborateurs ;
- assurer l'intégrité des informations afin d'éviter toute modification non autorisée ;
- garantir la disponibilité des services essentiels au fonctionnement de l'entreprise ;
- réduire l'exposition aux cybermenaces ;
- renforcer la maîtrise des risques liés aux prestataires et aux services Cloud ;
- améliorer la conformité aux exigences réglementaires et contractuelles ;
- inscrire la sécurité de l'information dans une démarche d'amélioration continue.

Ces objectifs seront suivis au moyen d'indicateurs définis dans le cadre du SMSI et feront l'objet d'une revue périodique par la Direction.

---

6. Principes directeurs de la sécurité

La sécurité de l'information chez BioMarket repose sur les principes suivants :

6.1 Confidentialité

Les informations doivent être accessibles uniquement aux personnes disposant d'une autorisation adaptée à leurs fonctions.

Les droits d'accès sont attribués selon le principe du **moindre privilège** et révisés régulièrement.

6.2 Intégrité

Les informations doivent être protégées contre toute modification non autorisée ou accidentelle.

Des mécanismes de contrôle, de journalisation et de validation des changements sont mis en œuvre afin de garantir la fiabilité des données.

6.3 Disponibilité

Les services informatiques doivent rester accessibles afin de garantir la continuité des activités de BioMarket.

Des sauvegardes régulières, des procédures de restauration et des dispositifs de supervision contribuent à maintenir un niveau de disponibilité adapté aux besoins de l'entreprise.

6.4 Traçabilité

Les actions réalisées sur les systèmes d'information doivent pouvoir être retracées grâce à la journalisation des événements et à la conservation des traces techniques.

Cette traçabilité facilite la détection des incidents, les investigations et les audits.

6.5 Responsabilisation

Chaque collaborateur est responsable de l'utilisation sécurisée des ressources qui lui sont confiées.

Le respect de la présente PSSI constitue une obligation pour l'ensemble des utilisateurs du système d'information.

---

7. Référentiels applicables

La présente politique s'appuie notamment sur les référentiels suivants :

Référentiel	Objet
ISO/IEC 27001	Exigences relatives au SMSI
ISO/IEC 27002	Bonnes pratiques de sécurité de l'information
RGPD	Protection des données personnelles
Guides ANSSI	Recommandations de cybersécurité
Documentation interne BioMarket	Procédures et règles internes

---

8. Définitions

Terme	Définition
SMSI	Système de Management de la Sécurité de l'Information
PSSI	Politique de Sécurité du Système d'Information
MFA	Authentification multifacteur
DSI	Direction des Systèmes d'Information
DPO	Délégué à la Protection des Données
Actif	Ressource ayant une valeur pour l'organisation

---

9. Organisation de la sécurité de l'information

9.1 Principe

La sécurité de l'information est une responsabilité collective. Chaque acteur intervenant sur le système d'information contribue, selon ses missions, à la protection des actifs informationnels de BioMarket.

La Direction veille à ce que les responsabilités soient clairement définies et que les moyens nécessaires soient mis à disposition pour assurer l'application de la présente politique.

9.2 Rôles et responsabilités

Direction Générale

La Direction Générale :

- valide la PSSI ;
- définit les orientations stratégiques en matière de cybersécurité ;
- alloue les ressources nécessaires ;
- valide les investissements liés à la sécurité ;
- participe aux revues de direction du SMSI.

Direction des Systèmes d'Information (DSI)

La DSI est responsable de la mise en œuvre opérationnelle de la PSSI.

À ce titre, elle :

- pilote le SMSI ;
- supervise les infrastructures informatiques ;
- coordonne les actions de sécurité ;
- suit les indicateurs de sécurité ;
- veille à la conformité des systèmes.

Délégué à la Protection des Données (DPO)

Le DPO veille au respect des obligations relatives à la protection des données personnelles.

Ses principales missions sont :

- conseiller la Direction sur les obligations du RGPD ;
- contrôler la conformité des traitements ;
- accompagner les analyses d'impact lorsque nécessaire ;
- assurer le lien avec la CNIL.

Responsable des Ressources Humaines

Le service RH participe à la sécurité en :

- informant la DSI des arrivées, mutations et départs des collaborateurs ;
- intégrant la cybersécurité dans le parcours d'intégration ;
- participant aux campagnes de sensibilisation.

Managers

Les responsables de service :

- veillent au respect de la PSSI ;
- signalent les besoins d'évolution des habilitations ;
- sensibilisent leurs équipes aux bonnes pratiques.

Utilisateurs

Chaque utilisateur doit :

- respecter les règles définies par la PSSI ;
- protéger ses identifiants ;
- signaler tout incident de sécurité ;
- utiliser les équipements conformément aux procédures internes.

Prestataires

Tout prestataire intervenant sur le système d'information doit :

- respecter les exigences de sécurité de BioMarket ;
- signer un engagement de confidentialité ;
- utiliser exclusivement les accès qui lui sont attribués ;
- signaler sans délai tout incident de sécurité.

9.3 Pilotage du projet et outils de suivi

Le projet de mise en œuvre du SMSI et de préparation à la certification ISO/IEC 27001 fait l'objet d'un suivi régulier au moyen d'outils de gestion de projet.

Les principaux outils utilisés sont les suivants :

Outil	Utilisation
Diagramme de Gantt	Suivi de l'avancement du projet et des jalons définis
Plan d'actions	Suivi des actions, des responsables, des échéances et de leur état d'avancement
Registre des risques	Identification, évaluation et suivi des risques du projet
Tableau de bord	Suivi des indicateurs d'avancement, de performance et de conformité
Comptes rendus du COPIL	Suivi des décisions, arbitrages et écarts constatés

Le diagramme de Gantt permet notamment de suivre les jalons du projet et les livrables associés. Le respect des jalons est vérifié lors des réunions du comité de pilotage. Tout écart significatif concernant l'avancement, les risques, les actions ou les jalons fait l'objet d'une analyse et, si nécessaire, d'une action corrective.

9.4 Critères d’acceptation des risques

BioMarket considère comme acceptables les risques résiduels de niveau **Faible ou Modéré**.
Les risques résiduels de niveau **Élevé ou Critique** doivent faire l’objet de mesures de sécurité complémentaires ou, lorsque leur maintien est justifié, d’une **décision formelle d’acceptation par la Direction Générale**.
Les risques relatifs à la protection des données personnelles sont examinés avec le **DPO**, notamment au regard des exigences du RGPD.

10. Politique de gestion des accès

10.1 Principes généraux

L'accès aux ressources du système d'information repose sur le principe du **moindre privilège**. Chaque utilisateur ne dispose que des droits strictement nécessaires à l'exercice de ses fonctions.

Les droits d'accès sont attribués selon un processus formalisé, validés par le responsable hiérarchique et revus régulièrement.

10.2 Gestion des identités

Tous les utilisateurs disposent d'un compte nominatif.

Les comptes génériques sont interdits, sauf justification technique validée par la DSI et documentée.

La création, la modification et la suppression des comptes sont réalisées selon une procédure définie.

Les comptes des collaborateurs quittant l'entreprise sont désactivés sans délai.

10.3 Authentification

Les règles suivantes sont appliquées :

- authentification nominative obligatoire ;
- mots de passe conformes à la politique de sécurité de BioMarket ;
- verrouillage automatique des sessions après une période d'inactivité ;
- interdiction du partage de comptes.

Une authentification multifacteur (MFA) est obligatoire pour :

- les comptes à privilèges ;
- les accès VPN ;
- les accès aux services Cloud ;
- les accès d'administration.

10.4 Comptes à privilèges

Les comptes administrateurs font l'objet de mesures spécifiques :

- utilisation exclusivement pour les tâches d'administration ;
- comptes distincts des comptes utilisateurs ;
- journalisation des actions ;
- revue régulière des habilitations ;
- suppression immédiate des privilèges devenus inutiles.

10.5 Accès distants

Les accès distants sont autorisés uniquement au travers du VPN SSL de BioMarket.

Les connexions doivent respecter les exigences suivantes :

- authentification forte ;
- certificat numérique lorsque applicable ;
- chiffrement des communications ;
- journalisation des connexions.

10.6 Revue des habilitations

Une revue des droits d'accès est réalisée au minimum deux fois par an, ainsi qu'à chaque changement significatif de poste.

Cette revue permet de vérifier que les habilitations restent adaptées aux fonctions exercées.

---

11. Gestion des actifs

11.1 Inventaire

Tous les actifs informationnels doivent être recensés dans un inventaire tenu à jour.

Chaque actif est identifié par :

- un identifiant unique ;
- un propriétaire ;
- une localisation ;
- un niveau de criticité ;
- un responsable de maintenance.

11.2 Propriétaire de l'actif

Chaque actif possède un propriétaire chargé :

- de définir les règles d'utilisation ;
- de valider les accès ;
- de signaler les évolutions ;
- de participer aux analyses de risques.

11.3 Cycle de vie

Les actifs suivent un cycle de vie comprenant :

- acquisition ;
- exploitation ;
- maintenance ;
- remplacement ;
- retrait sécurisé.

Les supports contenant des données sensibles sont effacés ou détruits conformément aux procédures internes avant leur élimination.

---

12. Classification de l'information

Les informations sont classifiées afin d'adapter leur niveau de protection.

Niveau	Description
Public	Diffusion libre
Interne	Réservé aux collaborateurs
Confidentiel	Accès limité aux personnes autorisées
Très confidentiel	Informations critiques nécessitant des mesures renforcées

Le niveau de classification détermine les règles applicables en matière d'accès, de stockage, de transmission et d'archivage.

---

13. Sécurité des postes de travail

Les postes de travail constituent un point d'entrée privilégié pour les cyberattaques.

Les mesures suivantes sont appliquées :

- verrouillage automatique après une période d'inactivité ;
- installation d'un antivirus ou EDR approuvé par la DSI ;
- mises à jour de sécurité automatiques ;
- interdiction d'installer des logiciels non autorisés ;
- chiffrement des postes mobiles lorsque cela est nécessaire ;
- limitation de l'utilisation des supports amovibles.

Les utilisateurs sont responsables du bon usage des équipements qui leur sont confiés.

---

14. Sécurité des réseaux

Le réseau de BioMarket doit garantir la confidentialité et l'intégrité des communications internes et externes.

Les mesures suivantes sont appliquées :

- segmentation du réseau en VLAN selon les profils d'utilisation ;
- filtrage des flux par des pare-feu ;
- utilisation d'un VPN SSL pour les accès distants ;
- sécurisation des connexions avec les services Cloud ;
- journalisation des événements réseau ;
- surveillance des équipements critiques.

Toute modification de l'architecture réseau doit être validée selon la procédure de gestion des changements.

15. Politique de sauvegarde et de restauration

15.1 Objectif

Les sauvegardes garantissent la disponibilité des données et permettent de restaurer les systèmes en cas de perte, de corruption ou de cyberattaque.

BioMarket met en œuvre une stratégie de sauvegarde adaptée à la criticité de ses données afin de limiter les interruptions d'activité.

15.2 Principes

Les sauvegardes doivent respecter les principes suivants :

- sauvegarde régulière des données critiques ;
- séparation entre les données de production et les sauvegardes ;
- protection des sauvegardes contre les accès non autorisés ;
- conservation selon une politique de rétention définie ;
- tests réguliers de restauration.

15.3 Règles applicables

Élément	Règle
Données critiques	Sauvegarde quotidienne
Données métiers	Sauvegarde quotidienne
Données RH	Sauvegarde quotidienne
Serveurs	Sauvegarde complète hebdomadaire
Tests de restauration	Au minimum une fois par trimestre
Journal des sauvegardes	Conservé et vérifié régulièrement

15.4 Responsabilités

La DSI est responsable :

- de la planification des sauvegardes ;
- du contrôle quotidien de leur bon déroulement ;
- de la réalisation des tests de restauration ;
- de la documentation des incidents liés aux sauvegardes.

---

16. Gestion des incidents de sécurité

16.1 Objectif

Tout événement susceptible de compromettre la confidentialité, l'intégrité ou la disponibilité du système d'information doit être traité selon une procédure définie.

16.2 Déclaration

Tout collaborateur doit signaler immédiatement :

- un poste compromis ;
- un courriel suspect ;
- une perte de matériel ;
- un accès non autorisé ;
- un comportement anormal du système.

Les signalements sont adressés à la DSI.

16.3 Traitement

Chaque incident suit les étapes suivantes :

1. Détection
2. Qualification
3. Contention
4. Éradication
5. Restauration
6. Retour d'expérience

Chaque incident fait l'objet d'une fiche d'incident permettant d'assurer sa traçabilité.

16.4 Notification

Lorsqu'un incident concerne des données personnelles, BioMarket applique les obligations prévues par le RGPD, notamment l'évaluation de la nécessité de notifier l'autorité compétente et, le cas échéant, les personnes concernées.

---

17. Gestion des changements

17.1 Objectif

Toute modification du système d'information doit être maîtrisée afin de limiter les risques de dysfonctionnement ou de régression.

17.2 Procédure

Chaque changement doit :

- être formalisé ;
- être évalué sur le plan des risques ;
- être validé avant sa mise en œuvre ;
- être testé lorsque cela est nécessaire ;
- être documenté.

17.3 Changements majeurs

Les changements suivants nécessitent une validation préalable de la DSI :

- modification des pare-feu ;
- évolution de l'architecture réseau ;
- création de nouveaux services ;
- modification des droits administrateurs ;
- évolution des applications métiers.

---

18. Développement sécurisé

18.1 Principes

Le développement de la plateforme e-commerce est réalisé par Iron4Software.

Afin de garantir un niveau de sécurité conforme aux exigences de BioMarket, les développements devront respecter les principes suivants :

- prise en compte de la sécurité dès la conception (*Security by Design*) ;
- validation des exigences de sécurité avant la mise en production ;
- gestion sécurisée des identifiants et secrets ;
- correction des vulnérabilités identifiées ;
- séparation des environnements de développement, de test et de production.

18.2 Gestion du code source

Les dépôts de code utilisés pour le développement devront :

- être privés ;
- être accessibles uniquement aux personnes autorisées ;
- faire l'objet de revues de code ;
- utiliser une gestion sécurisée des secrets.

18.3 Validation avant mise en production

Avant toute mise en production :

- des tests fonctionnels sont réalisés ;
- des tests de sécurité sont effectués ;
- la DSI valide le déploiement.

---

19. Sensibilisation et formation

19.1 Objectif

La sécurité de l'information repose également sur le comportement des utilisateurs.

BioMarket met en place un programme permanent de sensibilisation destiné à développer une culture de cybersécurité.

19.2 Programme

Le programme comprend notamment :

- formation des nouveaux collaborateurs ;
- sensibilisation annuelle ;
- campagnes de simulation de phishing ;
- rappels des bonnes pratiques ;
- diffusion d'alertes de sécurité.

19.3 Public concerné

Les actions concernent :

- Direction ;
- DSI ;
- RH ;
- managers ;
- collaborateurs ;
- prestataires intervenant sur le système d'information.

---

20. Conformité, audit et amélioration continue

20.1 Contrôle

Le respect de la présente PSSI est vérifié au moyen :

- d'audits internes ;
- de revues des habilitations ;
- de contrôles techniques ;
- d'indicateurs de sécurité.

20.2 Revue de direction

Une revue annuelle permet :

- d'évaluer l'efficacité du SMSI ;
- d'examiner les incidents significatifs ;
- d'analyser les résultats des audits ;
- de décider des actions d'amélioration.

20.3 Amélioration continue

La PSSI est revue :

- lors de tout changement majeur ;
- après un incident important ;
- à l'issue des audits ;
- au minimum une fois par an.

Cette démarche s'inscrit dans le cycle **PDCA (Plan – Do – Check – Act)** de l'ISO/IEC 27001.

---

21. Mesures de sécurité prioritaires

Afin de renforcer progressivement le niveau de sécurité de BioMarket, plusieurs mesures prioritaires ont été identifiées.

Action	**Budget estimatif**
A1 – MFA	15 000 €
A2 – Revue des habilitations	15 000 €
A3 – Politique mots de passe	10 000 €
A4 – Chiffrement BitLocker	15 000 €
A5 – Sauvegardes chiffrées	25 000 €
A6 – EDR	30 000 €
A7 – Journalisation centralisée / SIEM	30 000 €
A8 – Sensibilisation	10 000 €
A9 – Accès prestataire	20 000 €
A10 – Gestion des changements	5 000 €
A11 – Segmentation / isolation des serveurs critiques	20 000 €
TOTAL	**195 000 € HT**

Remarque : ces montants correspondent à une estimation des investissements associés aux principales mesures de sécurité.

Analyse comparative

Les mesures sont priorisées selon trois critères principaux :

· le niveau de risque traité ;

· le coût de mise en œuvre ;

· l'impact sur le fonctionnement de BioMarket.

Les actions prioritaires concernent notamment la protection des comptes et des accès, la protection contre les rançongiciels, la sécurisation des sauvegardes, la supervision du système d'information, la gestion des accès des prestataires et la segmentation des réseaux.

La mise en œuvre des mesures sera réalisée progressivement selon le niveau de risque, les dépendances techniques, les ressources disponibles et les priorités définies par le comité de pilotage.

22. Suivi du SMSI

Le pilotage du SMSI repose sur plusieurs indicateurs :

- comptes à privilèges protégés par MFA = 100 %
- revue des droits = 2 fois/an
- sauvegardes = 100 %
- collaborateurs formés > 95 %
- incidents critiques pris en charge < 1 h
- disponibilité ≥ 99,5 %
- non-conformités majeures = 0

Ces indicateurs sont examinés lors des réunions du comité de pilotage afin d'évaluer l'efficacité du SMSI et d'orienter les actions d'amélioration.

---

23. Validation de la PSSI

La présente Politique de Sécurité du Système d'Information est approuvée par la Direction Générale de BioMarket.

Elle entre en application à compter de sa date de validation et s'impose à l'ensemble des collaborateurs ainsi qu'aux prestataires intervenant sur le système d'information.

Toute dérogation à cette politique doit faire l'objet d'une validation formelle par la Direction des Systèmes d'Information.

Tableau des approbations

Fonction	Nom	Signature	Date
Direction Générale	Antoine Verger	AV	30/06/2026

Fonction	Nom	Signature	Date
Directrice des Systèmes d'Information	Mme Berthion	Berthion	30/06/2026
Délégué à la Protection des Données (DPO)	À désigner		
Consultant Cybersécurité	Quentin Berengolc	QB	30/06/2026

Conclusion

La présente PSSI formalise les règles de gouvernance et les mesures de sécurité applicables au système d'information de BioMarket. Elle traduit l'engagement de la Direction à protéger les actifs informationnels de l'entreprise, à respecter les exigences réglementaires et à inscrire la sécurité dans une démarche d'amélioration continue conforme aux principes de l'ISO/IEC 27001.

Cette politique constitue le document de référence pour l'ensemble des collaborateurs et des partenaires intervenant sur le système d'information. Elle sera complétée par des procédures opérationnelles, des guides utilisateurs et des contrôles réguliers destinés à garantir son application effective.

Annexes proposées

- **Annexe C1** : Matrice RACI de la sécurité.
- **Annexe C2** : Procédure de gestion des incidents.
- **Annexe C3** : Procédure de gestion des changements.
- **Annexe C4** : Procédure de gestion des habilitations.
- **Annexe C5** : Classification des informations et actifs informationnels
- **Annexe C6** : Programme annuel de sensibilisation,
- **Annexe C7** : Charte informatique.